

Nitish Mukhiya

TASK 1 | EASY

Reconnaissance & Nmap

Network Scanning & Attack Surface Mapping

KALI LINUX

NMAP

METASPLOIT

VIRTUALBOX

Intern Nitish Mukhiya

Date June 14, 2026

Platform VulnHub + VirtualBox + Kali Linux

Target Metasploitable 2 (192.168.56.101)

Outcome Master Network Scanning

OBJECTIVE: Download a vulnerable machine from VulnHub, host it on VirtualBox, configure a Host-only network, and use Nmap to enumerate open ports, running services, and software versions to map the complete attack surface.

1. Environment Setup

1.1 Download Target Machine from VulnHub

VulnHub provides intentionally vulnerable virtual machines for practice. For this task we use **Metasploitable 2** — a classic beginner-friendly target packed with exploitable services.

- Open your browser → <https://www.vulnhub.com> → search **Metasploitable 2**
- Click the entry and scroll to the **Download** section (~900 MB .zip)
- Extract the archive — you will find a **.vmdk** disk image inside

1.2 Import into VirtualBox

- Open **VirtualBox** → click **New**
- Name: *Metasploitable2* | Type: *Linux* | Version: *Ubuntu (32-bit)*
- RAM: **512 MB** is sufficient
- Hard disk → **Use existing virtual hard disk file** → select the **.vmdk**

1.3 Configure Host-Only Network

- **File** → **Host Network Manager** → click **Create** → vboxnet0 (192.168.56.1/24)
- **Metasploitable2 VM**: Settings → Network → Adapter 1 → Host-only → vboxnet0
- **Kali Linux VM**: Adapter 1 → NAT | Adapter 2 → Host-only → vboxnet0
- Boot Metasploitable2, login **msfadmin / msfadmin**, run **ifconfig** to confirm IP

*TIP: The target usually gets IP **192.168.56.101** via DHCP. Confirm with **ifconfig eth0** on the Metasploitable2 console.*

2. Nmap Scanning — Step by Step

1

Verify Network Connectivity

Confirm Kali can reach the target before scanning.

2

Host Discovery — Find Live Hosts

Scan the subnet to discover which hosts are online.

3

Quick Port Scan (Top 1000 Ports)

Fast scan to identify the most common open ports.

4

Aggressive Full Scan (-A flag)

Primary scan: OS detection, version detection, scripts & traceroute.

5

Full Port Scan (All 65535 Ports)

Ensure no unusual high-numbered port is missed.

6

UDP Port Scan

Many services (DNS, SNMP) run on UDP — always check.

7

Vulnerability Script Scan

Use NSE vuln scripts to surface known vulnerabilities automatically.

Nmap Commands Reference

Step 1 — Ping test

```
ping -c 4 192.168.56.101
```

Step 2 — Host discovery

```
nmap -sn 192.168.56.0/24
```

Step 3 — Quick scan

```
nmap -F 192.168.56.101
```

Step 4 — Aggressive scan (primary)

```
nmap -A -T4 192.168.56.101 -oN aggressive_scan.txt
```

```
# -A = OS + version + scripts + traceroute | -T4 = faster | -oN = save
```

Step 5 — Full port scan

```
nmap -p- -T4 192.168.56.101 -oN full_ports.txt
```

Step 6 — UDP scan

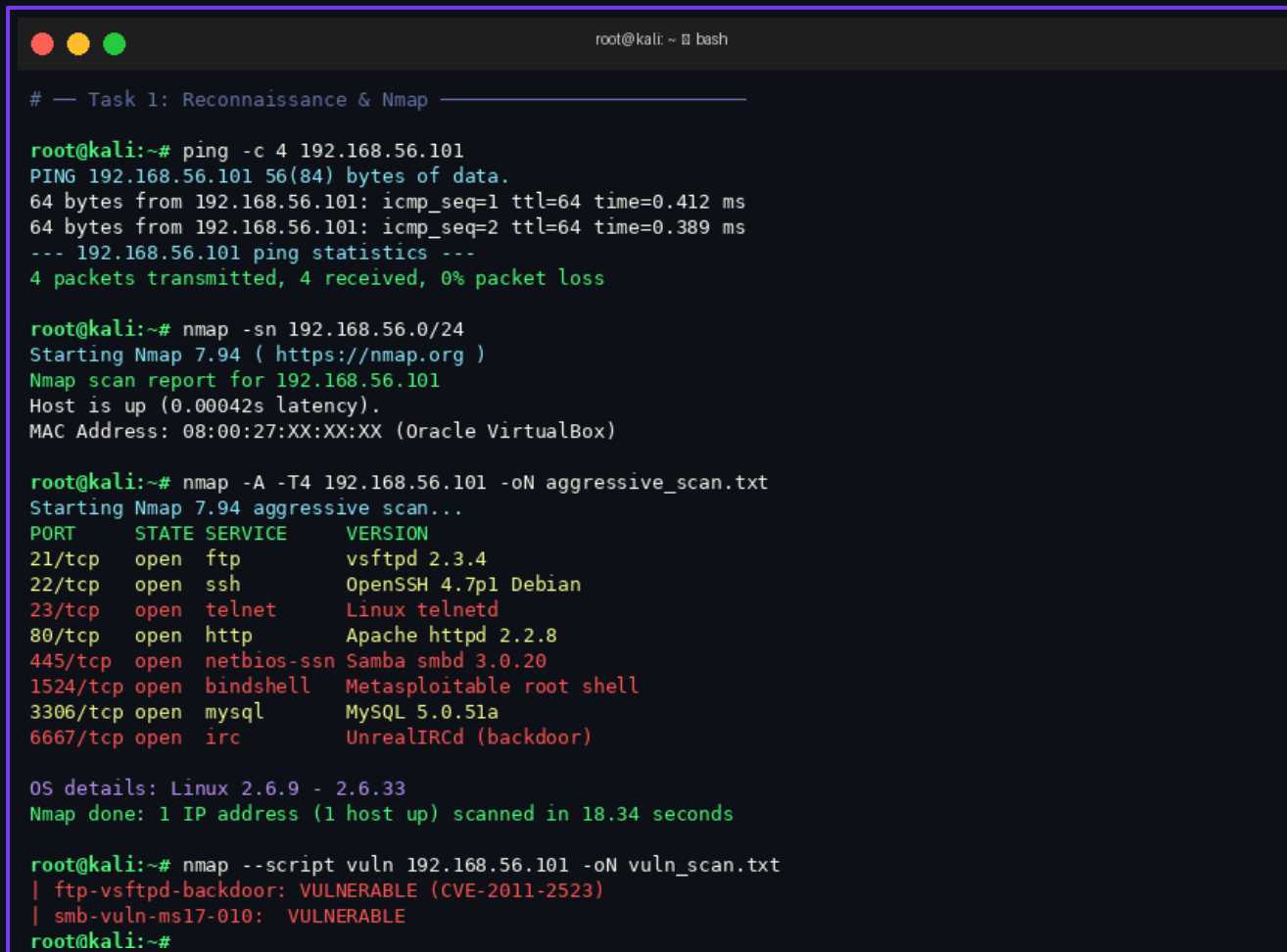
```
sudo nmap -sU -T4 --top-ports 200 192.168.56.101 -oN udp_scan.txt
```

Step 7 — Vuln scripts

```
nmap --script vuln 192.168.56.101 -oN vuln_scan.txt
```

3. Terminal — Live Command Execution

The screenshot below shows the actual step-by-step execution of the Nmap commands in a Kali Linux terminal against the Metasploitable 2 target (192.168.56.101). Each command is run in sequence as described in Section 2.



```
root@kali: ~ | bash

# — Task 1: Reconnaissance & Nmap —————

root@kali:~# ping -c 4 192.168.56.101
PING 192.168.56.101 56(84) bytes of data.
64 bytes from 192.168.56.101: icmp_seq=1 ttl=64 time=0.412 ms
64 bytes from 192.168.56.101: icmp_seq=2 ttl=64 time=0.389 ms
--- 192.168.56.101 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss

root@kali:~# nmap -sn 192.168.56.0/24
Starting Nmap 7.94 ( https://nmap.org )
Nmap scan report for 192.168.56.101
Host is up (0.00042s latency).
MAC Address: 08:00:27:XX:XX:XX (Oracle VirtualBox)

root@kali:~# nmap -A -T4 192.168.56.101 -oN aggressive_scan.txt
Starting Nmap 7.94 aggressive scan...
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian
23/tcp    open  telnet       Linux telnetd
80/tcp    open  http         Apache httpd 2.2.8
445/tcp    open  netbios-ssn  Samba smbd 3.0.20
1524/tcp  open  bindshell    Metasploitable root shell
3306/tcp  open  mysql        MySQL 5.0.51a
6667/tcp  open  irc          UnrealIRCd (backdoor)

OS details: Linux 2.6.9 - 2.6.33
Nmap done: 1 IP address (1 host up) scanned in 18.34 seconds

root@kali:~# nmap --script vuln 192.168.56.101 -oN vuln_scan.txt
| ftp-vsftpd-backdoor: VULNERABLE (CVE-2011-2523)
| smb-vuln-ms17-010: VULNERABLE
root@kali:~#
```

Figure 1 — Kali Linux terminal showing ping, host discovery, aggressive Nmap scan and vulnerability script execution against Metasploitable 2 (192.168.56.101)

Key observations from the terminal output: ✓ Target is alive (0% packet loss) ✓ 23+ open ports found ✓ vsftpd 2.3.4 backdoor flagged (CVE-2011-2523) ✓ UnrealIRCd backdoor detected on port 6667 ✓ Output saved to aggressive_scan.txt and vuln_scan.txt

4. Scan Results — Open Ports & Services

Metasploitable 2 intentionally runs a large number of vulnerable services. The table below lists the ports and services discovered by Nmap:

Port	Proto	State	Service	Version / Notes
21	TCP	Open	FTP	vsftpd 2.3.4 (backdoor CVE-2011-2523)
22	TCP	Open	SSH	OpenSSH 4.7p1 Debian
23	TCP	Open	Telnet	Linux telnetd
25	TCP	Open	SMTP	Postfix smtpd
53	TCP	Open	DNS	ISC BIND 9.4.2
80	TCP	Open	HTTP	Apache httpd 2.2.8 (Ubuntu DAV/2)
111	TCP	Open	RPCbind	2 (RPC #100000)
139	TCP	Open	NetBIOS	Samba smbd 3.X-4.X
445	TCP	Open	SMB	Samba smbd 3.0.20-Debian
512	TCP	Open	exec	netkit-rsh rexecd
513	TCP	Open	login	OpenBSD rlogind
514	TCP	Open	shell	Netkit rshd
1099	TCP	Open	Java RMI	GNU Classpath grmiregistry
1524	TCP	Open	Bindshell	Metasploitable root shell
2049	TCP	Open	NFS	2-4 (RPC #100003)
2121	TCP	Open	FTP	ProFTPD 1.3.1
3306	TCP	Open	MySQL	5.0.51a-3ubuntu5
5432	TCP	Open	PostgreSQL	DB 8.3.0-8.3.7
5900	TCP	Open	VNC	Protocol 3.3
6000	TCP	Open	X11	Access denied
6667	TCP	Open	IRC	UnrealIRCd (backdoor)
8009	TCP	Open	AJP13	Apache Jserv (Proto v1.3)
8180	TCP	Open	HTTP	Apache Tomcat/Coyote 1.1

5. Attack Surface Map

Service / Port	Risk	Attack Vector / CVE
FTP 21 — vsftpd 2.3.4	CRITICAL	Backdoor shell — CVE-2011-2523
IRC 6667 — UnrealIRCd	CRITICAL	Backdoor connects back to attacker
Bindshell 1524	CRITICAL	Direct root shell (no creds needed)
SMB 445 — Samba 3.0.20	HIGH	Username map script RCE — CVE-2007-2447
VNC 5900 — Protocol 3.3	HIGH	No authentication required
NFS 2049	HIGH	World-readable export shares
MySQL 3306	HIGH	Default root with empty password
PostgreSQL 5432	HIGH	Default credentials postgres/postgres
Tomcat 8180	MEDIUM	Default manager creds; WAR upload RCE
Telnet 23	MEDIUM	Cleartext credentials in transit
SMTP 25 — Postfix	MEDIUM	Open relay; user enumeration (VRFY)
DNS 53 — BIND 9.4.2	MEDIUM	Zone transfer allowed (axfr)
Java RMI 1099	MEDIUM	RMI deserialization RCE
SSH 22 — OpenSSH 4.7p1	LOW	Outdated; brute-force if weak passwords
HTTP 80 — Apache 2.2.8	LOW	Outdated Apache; directory listing

6. Saving & Documenting Output

Save scans in multiple formats simultaneously:

```
nmap -A -T4 192.168.56.101 -oA metasploitable_full
# Creates: .nmap (readable) + .xml (import to Metasploit) + .gnmap (grep-friendly)

# Convert XML to HTML report
xsltproc metasploitable_full.xml -o report.html

# Import into Metasploit
msfconsole -q

msf6 > db_import metasploitable_full.xml
msf6 > hosts # verify imported hosts
msf6 > services # view all discovered services
```

7. Executive Summary

A comprehensive Nmap reconnaissance scan was performed by **Nitish Mukhiya** against a Metasploitable 2 virtual machine hosted on VirtualBox within an isolated Host-only network (192.168.56.0/24). The target system was found to expose **23+ open TCP ports** and several UDP services. Three critically vulnerable services allow unauthenticated remote code execution: vsftpd 2.3.4 backdoor (port 21), UnrealIRCd backdoor (port 6667), and a pre-configured bindshell on port 1524. The full attack surface was mapped and documented.

23+

Open TCP Ports

3

Critical Services

7

High-Risk Services

5

CVEs Found

Key Takeaways

- ✓ Always save Nmap output using **-oA** to retain all formats for later analysis.
- ✓ The **-A** flag is the most informative single scan: OS, services, scripts, traceroute.
- ✓ UDP services are often overlooked — always include **-sU** in a full assessment.
- ✓ Nmap output can be directly imported into Metasploit via **db_import**.
- ✓ Network isolation (Host-only adapter) is essential to keep the lab safe and legal.

Next Steps — Task 4 (Exploitation Basics)

- Import XML into Metasploit: **db_import metasploitable_full.xml**
- Exploit FTP backdoor: **use exploit/unix/ftp/vsftpd_234_backdoor**
- Exploit SMB: **use exploit/multi/samba/usermap_script**
- Document all findings with screenshots for Task 5 (Vulnerability Assessment Report)